



AURORA - BY NVEXIS - SECURITY REPORT

Penetration Testing - Options, Pricing & Recommendation

Who can pen-test Aurora before it charges real money, what it should cost in 2026, and the cheapest reputable option for a solo SaaS.

Prepared 16 July 2026 - Confidential strategy document - Aurora is a product of Nvexis

Executive summary

Aurora is a multi-tenant SaaS that will hold user data and take payments, so an independent **web-application + API penetration test** is the right pre-launch check (already a go-live gate). An internal security review has already found and fixed the high-impact issues, so a tester's time can go straight to deeper testing rather than rediscovering known bugs.

\$4k-\$8k

Reputable seed-stage web-app + API pentest (2026)

\$1.5k-\$3k

Vetted independent certified tester (budget route)

\$0

Bugs a tester finds free because you fixed the known ones first

Recommendation for Aurora now: a **focused, fixed-scope web-app + API test in the \$4,000-\$8,000 band** from a startup-focused boutique or a vetted independent OSCP/OSWE tester, with a free retest of fixes included. If cash is tight pre-revenue, a carefully vetted independent at \$1,500-\$3,000 is a legitimate cheaper option - provided you check certifications, a sample report, and that a retest is included.

What kind of test Aurora needs

Not a full red-team or network engagement. Aurora needs a **gray-box web-application & API assessment** focused on multi-tenant SaaS risks:

- **Multi-tenant isolation / IDOR** - the single most important area. With two+ tenant accounts, attempt cross-tenant read/write on every table and every `/rpc/` function (the internal review flagged the RPC surface specifically).
- **Authentication & session** - Supabase Auth flows, JWT handling, password reset, OAuth.
- **RLS & privilege escalation** - can a user change their own plan, read others' billing data, or forge notifications? (All hardened in the recent remediation.)
- **Payment/webhook integrity** - Dodo webhook signature, idempotency, entitlement path.
- **Standard web classes** - XSS/CSP, SSRF, injection, file-upload/storage abuse, rate limiting.

Scope: roughly **one web app + its API/RPC surface, two user roles, a seeded staging environment** - typically 5-8 tester-days plus reporting.

2026 pricing landscape

Option	Typical price	Best for	Notes
Vetted independent tester (OSCP/OSWE) via Upwork/Toptal/referral	\$1,500-\$3,500	Pre-revenue solo	Cheapest reputable; quality varies - vet hard.
Startup-focused boutique / PTaaS	\$4,000-\$8,000	Seed-stage SaaS	Fixed scope: 1 app, 1-2 roles, few endpoints; 5-7 days + report. Best value/credibility balance.
Crowdsourced (Intigriti / HackerOne / Bugcrowd)	Variable / bounty	Ongoing coverage	Great continuous testing, but not a point-in-time report an enterprise buyer wants.

Established firm (compliance-grade, SOC 2)	\$15,000-\$35,000+	Series A+ / enterprise	Overkill now; revisit when a customer requires it.
Full red-team engagement	\$50,000-\$100,000+	Mature programs	Not relevant at this stage.

Sources: Autonomia, SecureLeap, RedFox, BlazeInfoSec, BrightDefense, BSG, Synack, Invicti - 2026 pentest pricing guides. Common caveat: final invoices often land 40-60% above the initial quote once retests and out-of-scope findings are added.

Cheapest reputable option - and how to vet it

Best value for Aurora today is a **startup-focused boutique or a single strong independent certified tester** at the low end (\$1.5k-\$4k). "Cheap" only counts if it's real testing, so require:

- **Certifications:** OSCP minimum; OSWE (web) a strong plus.
- **A sanitized sample report:** clear repro steps, risk ratings, remediation - not an automated-scanner dump.
- **Methodology:** OWASP Web Security Testing Guide / OWASP Top 10 and PTES.
- **A free retest** of fixes included.
- **Manual testing**, not scanner-only - tools miss the IDOR/business-logic flaws that are Aurora's main risk.
- **References** from other small SaaS clients.

Avoid the "\$300 automated scan" listings - those run a tool you could run yourself and won't find the multi-tenant logic flaws that actually threaten a SaaS.

How to cut the cost (do this first)

- **Fix known findings first** - done. Don't pay an expert to rediscover patched bugs.
- **Provide a seeded staging environment** with two+ tenants, sample data, one Pro + one Free account.
- **Hand over docs** - data model, RLS/security notes, RPC endpoint list. Gray-box is faster/cheaper than black-box.
- **Tightly scope** - one app, its API/RPC, two roles. Resist infra/network creep.

Recommendation for Aurora

1. **Now (pre-charging at scale):** commission a **focused web-app + API pentest, \$4,000-\$8,000**, from a startup-focused boutique with a retest included. If pre-revenue and cash-constrained, a vetted independent OSCP/OSWE tester at **\$1,500-\$3,000** is an acceptable first pass.
2. Give them a seeded two-tenant staging site + security docs to minimize hours.
3. Remediate findings, take the free retest, then flip Dodo to live and open paid signups.
4. **Later (enterprise / SOC 2):** move to an established firm only when a customer requires a named-firm report.
5. **Optionally ongoing:** a crowdsourced program for continuous coverage between annual tests.

Sources

Autonoma, SecureLeap, RedFox Security, Blaze Information Security, Bright Defense, BSG, Synack, Invicti - "Penetration Testing Cost 2026" guides; OWASP Web Security Testing Guide; PTES. Prices are 2026 market ranges and vary by scope, region and vendor; get 2-3 quotes.